



Межсайтовый перехват WebSocket

В этом упражнении рассматривается межсайтовый перехват WebSocket и способы получения доступа к конфиденциальной информации с его помощью.

PRO

Средний

< 1 ч.

1130

Оранжевый значок

2 видео

Лаборатория

Разверните выделенный экземпляр для этого упражнения.

↑ Развернуть

Во-первых, нужно заставить жертву перейти на вашу страницу, чтобы провести атаку CSWSH:

URL -адрес:

Поисковые упражнения...

Submit

Чтобы отметить это упражнение как выполненное, вам нужно отправить ключ, который вы получите после его выполнения:

xxxxxxxx-xxxx-xxxx-xxxx-xxxxxxxxxxxx

Отправить

⚠ Пожалуйста, не публикуйте никаких общедоступных отчетов о наших ПРОФЕССИОНАЛЬНЫХ упражнениях. Спасибо!

Видео



CSWSH - Введение
05:14



CSWSH: эксплуатация
09:16

Курс

Вам нравится эта бесплатная лаборатория?

Это лишь малая часть того, что вы получите с PentesterLab PRO! Получите доступ к сотням реальных лабораторий и видео, посвященных веб-хакингу, проверке кода и анализу уязвимостей CVE.

Разблокировать все лаборатории — стать PRO!



Внедрение SameSite в браузерах может ограничить возможности использования этой уязвимости. Жертва использует старый браузер, в котором не применяется SameSite=Lax.

ВВЕДЕНИЕ

В этом курсе подробно рассматривается использование уязвимости, связанной с перехватом межсайтовых веб-сокетов (Cross-Site WebSocket Hijacking, CSWSH).

Курс основан на следующей статье: [Перехват межсайтовых веб-сокетов \(Cross-Site WebSocket Hijacking, CSWSH\)](#), и описании Bug Bounty: [Захват аккаунта с использованием перехвата межсайтовых веб-сокетов \(Cross-Site WebSocket Hijacking, CSWSH\)](#).

Если вы чувствуете себя уверенно, можете попробовать выполнить это упражнение без сопровождения курса, а затем вернуться к курсу, чтобы ознакомиться с подробностями и советами.

Если вы хотите сделать это самостоятельно, выполните следующие действия:

- Изучите, как используется WebSocket и как работает аутентификация.
- Напишите вредоносную страницу для доступа к WebSocket.
- Используйте свою вредоносную страницу, чтобы отправить команду /getkey и передать результат на свой сервер.

МЕЖСАЙТОВЫЙ ПЕРЕХВАТ ЧЕРЕЗ WEBSOCKET

В отличие от XMLHttpRequest, WebSockets не подчиняются политике одинакового происхождения.

Например, веб-сайт, размещенный на Origin A, может использовать WebSocket для подключения к Origin B (и чтения/записи контента из/в WebSocket по умолчанию).

В рамках этого подключения файлы cookie пользователя Origin B будут отправлены в Origin B.



Это означает, что если приложение использует файлы cookie для аутентификации/авторизации, злоумышленник может заставить жертву зайти на [Origin B](#) через [WebSocket](#), и потенциально получить доступ к конфиденциальным данным этого пользователя или изменить их.

Чтобы избежать этой проблемы, серверная часть должна проверять заголовок [Origin](#), чтобы убедиться, что [Origin](#) является частью строгого белого списка.

ИСПОЛЬЗОВАНИЕ УЯЗВИМОСТИ

Чтобы воспользоваться этой уязвимостью, вам нужно создать вредоносную HTML-страницу, которая будет подключаться к серверной части и считывать/записывать информацию.

Вы можете использовать код уязвимого приложения, чтобы понять, как использовать [WebSockets](#).

Это должно позволить вам подключиться к серверной части. После того как вы подключитесь к серверу через сокет и отправите команду `/getkey`, вам нужно будет передать информацию обратно на свой сервер.

Самый простой способ — создать тег `<img>`, указывающий на ваш вредоносный сервер, и встроить в URL-адрес утекшие данные.

ЗАКЛЮЧЕНИЕ

Это упражнение показало вам, как взломать сайт, который не проверяет [Origin](#) при работе с [WebSockets](#).

Это позволило вам установить связь с сокетом вредоносного сайта и получить доступ к конфиденциальной информации.

Надеюсь, вам понравилось учиться с PentesterLab.

[PREVIOUS](#)
[Cross-Origin Resource Sharing II](#)

[NEXT](#)
[postMessage\(\)](#)

[Exercises](#)

[Live Training](#)

[Blog](#)

[Glossary](#)

[Support](#)

[Merch](#)

© 2026 PentesterLab